

Security Operations Center (SOC) Investigation Report

Executive Summary

A phishing- related security incident was investigated on workstation 10.10.20.45 involving user finance.user. The investigation revealed the execution of Powershell,establishment of an encrypted connection to the external IP 91.214.66.77 (domain: update- security-check.net),creation of an unauthorized local administrator account (backup.support), and persistence through a scheduled task named windows update monitor . The attacker later accessed the corporate file server, compressed sensitive data using 7z,exe, and ex-filtrated, approximated 2.8gb data over HTTPS. Based on the investigation finding , including privilege escalation, persistent access ,and confirmed data ex-filtration , the incident was classified as Critical and recommended for immediate escalation to the incident Response team for containment. Forensic analysis and recondition

Incident Timeline

Time	Attack Stage	Activity
09:02 AM	Initial Access	Employee (finance.user) received a phishing email containing a malicious attachment.
09:04 AM	User Execution	The user opened the malicious attachment, triggering the attack.
09:05 AM	Execution	powershell.exe executed an encoded PowerShell command.
09:08 AM	Command and Control (C2)	The compromised host established an HTTPS connection to 91.214.66.77 (update-security-check.net).
09:20 AM	Privilege Escalation	The attacker created a new local administrator account (backup.support).

Time	Attack Stage	Activity
09:35 AM	Persistence	A scheduled task named Windows Update Monitor was created to maintain persistence.
09:50 AM	Defense Evasion / Credential Misuse	A VPN login from an unusual geographic location was detected using compromised credentials.
10:15 AM	Lateral Movement	The attacker accessed the corporate file server.
10:40 AM	Collection	Sensitive files were compressed using 7z.exe before exfiltration.
11:00 AM	Exfiltration	Approximately 2.8 GB of data was transferred to the external server over HTTPS.

Indicators of Compromise (IOCs)

IOC Type	Indicator	Description
User Account	finance.user	User account targeted by the phishing email.
Unauthorized Account	backup.support	Malicious local administrator account created by the attacker.
Process	powershell.exe	Executed encoded PowerShell commands to initiate the attack.
Process	rundll32.exe	Used to execute malicious DLLs and evade detection.
Process	7z.exe	Used to compress sensitive files before exfiltration.
Scheduled Task	Windows Update Monitor	Persistence mechanism created to maintain attacker access.
Source IP	10.10.20.45	IP address of the compromised workstation.
Destination IP	91.214.66.77	External command-and-control (C2) server.
Domain	update-security-check.net	Malicious domain used for attacker

IOC Type	Indicator	Description
		communication.
Protocol	HTTPS	Encrypted communication used for C2 and data exfiltration.
Connection Pattern	Every 5 Minutes	Regular beaconing between the compromised host and the C2 server.
VPN Activity	Login from Unusual Country	Suspicious VPN authentication indicating compromised credentials.
Data Exfiltration	2.8 GB Outbound Transfer	Large volume of sensitive data transferred outside the network.

Initial Access Analysis

The investigation found that the attack began with a phishing email sent to finance.user. After the user opened the malicious attachment at 09:04 AM, a PowerShell command was executed on the workstation. This established an encrypted HTTPS connection to the external IP address 91.214.66.77, allowing the attacker to communicate with the compromised system.

Once the connection was established, the attacker gained remote access and continued the attack by creating persistence, escalating privileges, and carrying out additional malicious activities within the network. Based on these findings, the initial access vector was identified as a phishing email with a malicious attachment.

Evidence

- Target User: finance.user
- Initial Access Method: Phishing email with malicious attachment
- User Action: Opened the attachment
- Execution: Encoded PowerShell command
- Command and Control: HTTPS connection to 91.214.66.77 (*update-security-check.net*)

Persistence Mechanisms

The investigation identified that the attacker established persistence by creating a scheduled task named Windows Update Monitor. This task was configured to execute automatically, allowing the attacker to maintain access to the compromised system even after a reboot or user logoff.

In addition, the attacker created an unauthorized local administrator account named backup.support. This account provided continued privileged access to the system and could be used to regain control if the original malicious process was terminated.

These persistence mechanisms allowed the attacker to maintain long-term access to the compromised environment and continue malicious activities without requiring repeated exploitation.

Privilege Escalation Techniques

The investigation determined that the attacker achieved privilege escalation by creating an unauthorized local administrator account named backup.support. This account granted administrative privileges on the compromised system, allowing the attacker to execute privileged commands, modify system settings, and access protected resources.

The creation of a privileged account enabled the attacker to maintain elevated access throughout the attack, facilitating persistence, lateral movement, and the exfiltration of sensitive organizational data.

Attacker Objectives

Based on the investigation, the attacker's primary objective was to gain unauthorized access to the corporate network and steal sensitive organizational data. After compromising the user's workstation, the attacker established persistence, obtained administrative privileges, and moved laterally to the corporate file server.

The attacker then collected and compressed sensitive files using 7z.exe before exfiltrating approximately 2.8 GB of data over an encrypted HTTPS connection. These actions indicate that the attacker intended to maintain access, gather valuable information, and successfully exfiltrate data while minimizing the likelihood of detection.

MITRE ATT&CK Mapping

Observed Behaviour	MITRE ATT&CK Tactic	Technique Name	Technique ID
Phishing email with malicious attachment	Initial Access	Phishing	T1566
User opened the malicious attachment	Execution	User Execution	T1204.002
Encoded PowerShell execution	Execution	PowerShell	T1059.001
HTTPS connection to external server	Command and Control	Application Layer Protocol (HTTPS)	T1071.001
Creation of local administrator account (backup.support)	Persistence / Privilege Escalation	Create Local Account	T1136.001
Scheduled task (Windows Update Monitor)	Persistence	Scheduled Task/Job	T1053.005
VPN login using compromised credentials	Defense Evasion / Persistence	Valid Accounts	T1078
Access to corporate file server	Lateral Movement	Remote Services	T1021
Compression of files using 7z.exe	Collection	Archive Collected Data	T1560.001
Transfer of 2.8 GB of data over HTTPS	Exfiltration	Exfiltration Over Web Services	T1567.002

Incident Severity

Critical

The incident was assigned a Critical severity based on the following factors:

1. Confirmed System Compromise: The attacker gained unauthorized access, executed malicious PowerShell commands, and established persistence on the compromised workstation.
2. Privilege Escalation and Lateral Movement: The attacker created a local administrator account, accessed the corporate file server, and maintained elevated privileges within the environment.

3. **Data Exfiltration:** Approximately 2.8 GB of sensitive organizational data was successfully exfiltrated, posing a significant risk to the organization's confidentiality and business operations.

Business Impact

- **Data Loss:** The attacker successfully exfiltrated approximately 2.8 GB of sensitive organizational data, creating a significant confidentiality risk.
- **Operational Disruption:** The compromised workstation had to be isolated and investigated, affecting normal business operations.
- **Reputational and Financial Risk:** The data breach could result in reputational damage, financial losses, and potential legal or regulatory consequences.

Recommended Containment Actions

- **Isolate the Compromised System:** Disconnect the affected workstation from the network to prevent further attacker activity.
- **Disable Unauthorized Accounts:** Disable the malicious backup.support administrator account and review all recently created user accounts.
- **Reset Credentials:** Reset passwords for the affected user (finance.user) and any other accounts that may have been compromised.
- **Remove Persistence Mechanisms:** Delete the malicious scheduled task (Windows Update Monitor) and verify that no additional persistence methods exist.
- **Block Malicious Indicators:** Block the malicious IP address (91.214.66.77) and domain (update-security-check.net) at the firewall, proxy, and DNS levels.
- **Perform Enterprise Threat Hunting:** Search all endpoints and servers for the identified Indicators of Compromise (IOCs) to identify any additional compromised systems.
- **Collect Forensic Evidence:** Preserve system logs, memory, and disk images for forensic analysis before making significant system changes.
- **Conduct Full Malware Scans:** Perform comprehensive antivirus and EDR scans across the environment to ensure all malicious files and processes are removed.

Detection Improvements

- **Enable PowerShell Logging:** Configure Script Block Logging and Module Logging to detect malicious PowerShell activity.
- **Deploy Sysmon Across Endpoints:** Use Sysmon to improve visibility into process creation, network connections, and file modifications.
- **Enhance SIEM Detection Rules:** Create alerts for encoded PowerShell execution, administrator account creation, scheduled task creation, and privilege escalation.
- **Monitor VPN Activity:** Generate alerts for VPN logins from unusual geographic locations or impossible travel scenarios.
- **Detect Beaconing Traffic:** Monitor for repeated outbound HTTPS connections to unknown external IP addresses and domains.
- **Monitor Large Data Transfers:** Implement alerts for abnormal outbound network traffic that may indicate data exfiltration.
- **Implement Data Loss Prevention (DLP):** Deploy DLP controls to detect and prevent unauthorized transfer of sensitive information.
- **Strengthen Email Security:** Improve email filtering, block malicious attachments, and scan URLs to reduce phishing attacks.
- **Enforce Multi-Factor Authentication (MFA):** Require MFA for VPN, email, and privileged accounts to reduce the risk of credential compromise.
- **Conduct Regular Security Awareness Training:** Train employees to recognize phishing emails and report suspicious activity promptly.

Analyst Reflection

This investigation demonstrated how a single phishing email can quickly develop into a full-scale security incident if not detected at an early stage. The attack progressed through multiple phases, including PowerShell execution, privilege escalation, persistence, lateral movement, and data exfiltration, highlighting the importance of continuous monitoring and timely incident response.

During the investigation, correlating alerts from multiple log sources such as EDR, SIEM, VPN, and Windows event logs was essential in understanding the attack timeline and identifying the attacker's actions. This reinforced the value of integrating different security tools to improve visibility across the environment.

The incident also highlighted several opportunities to strengthen the organization's security posture. Improved email security, enhanced PowerShell monitoring, stronger SIEM detection rules, and regular security awareness training can help detect and prevent similar attacks in the future.

Overall, this investigation provided valuable experience in analyzing a multi-stage cyberattack, applying the MITRE ATT&CK framework, and documenting the incident in a structured SOC investigation report. The lessons learned from this incident will support faster detection, more effective response, and improved security monitoring going forward.

Conclusion

The investigation confirmed that the incident was a critical phishing-based cyberattack that resulted in the compromise of a user workstation and the exfiltration of sensitive organizational data. The attacker successfully established persistence, escalated privileges, accessed internal resources, and transferred approximately 2.8 GB of data to an external server.

The SOC team responded promptly by identifying the attack, isolating the affected system, removing malicious persistence, disabling unauthorized accounts, and blocking the identified malicious network indicators. These actions helped contain the incident and prevent further compromise.

This incident highlights the importance of proactive security monitoring, timely incident response, and layered security controls. Strengthening email security, enhancing endpoint monitoring, improving SIEM detection rules, and providing regular security awareness training will help reduce the risk of similar attacks in the future. Continuous monitoring and periodic threat hunting are recommended to improve the organization's overall cybersecurity posture.